

AI GOVERNANCE ASSURANCE PORTFOLIO

ApexCloud Enterprise AI Governance Readiness & Controls Assessment

A fictional large-technology-company engagement simulation aligned to the work of an AI Governance Senior Associate

Prepared by: Jun Jie Oh, U.S. CPA, Singapore CA

Case date: July 2026

Portfolio status: Completed case design and executed synthetic TalentMatch testing; RevenueIQ control results are illustrative assessment scenarios.

Fictional client: ApexCloud Technologies, Inc. - a public global cloud and enterprise-software company.

Executive decision: Do not permit the four Critical-tier use cases to enter or remain in production without accountable ownership, completed impact assessments, independent validation, approved human-oversight procedures, evidence-retention controls, and a model/vendor change gate. Permit lower-tier use cases only under documented interim conditions while the enterprise program is operationalized.

Purpose and truth boundary

This portfolio demonstrates how I would structure a risk-based AI governance advisory and assurance-readiness engagement: define scope, build an inventory, tier use cases, map requirements, design controls, test a system, evaluate evidence, report findings, and translate technical risk into an executive action plan.

- All company, system, people, documents, and control results are fictional or synthetic. No real client confidential information is used.
- The TalentMatch Python/SQL exercise was actually executed on generated data. RevenueIQ findings and evidence are clearly labeled illustrative.
- This is not PwC work, a legal opinion, an ISO certification assessment, an audit or attestation report, or a real independent bias audit.

What this package proves

Governance design (operating model, lifecycle gates, RACI and inventory); risk and controls (tiering, impact assessment, RCM, evidence and procedures); technical testing (seeded Python model, subgroup/performance/drift metrics and SQL validation); framework application (NIST AI RMF and ISO/IEC 42001-aligned deliverables); and executive communication (disposition, findings, roadmap and decision-led presentation).

1. Fictional client context and engagement scope

ApexCloud Technologies is assumed to be an SEC-registered technology company with approximately \$18 billion in annual revenue, 28,000 employees, operations in more than 30 jurisdictions, and enterprise cloud, cybersecurity, developer-tooling, and data products used by regulated customers. AI is developed internally, embedded in third-party SaaS, and consumed through foundation-model APIs.

Why the engagement is needed

- Decentralized AI adoption created incomplete visibility over models, agents, embedded vendor AI, and employee-created automations.
- Four use cases affect financial reporting, employment, external disclosures, or production infrastructure and therefore require higher assurance.
- The Audit Committee wants evidence that governance, risk, security, privacy, data, model development, monitoring, and incident processes operate as one control system.
- Management wants a practical roadmap that protects critical decisions without imposing the same control burden on low-risk productivity tools.

Engagement objectives

1. Establish an enterprise AI inventory and common metadata standard.
2. Apply a four-tier methodology with regulatory and materiality overrides.
3. Assess governance design and evidence readiness against NIST AI RMF and an ISO/IEC 42001-aligned management-system model.
4. Deep-dive a finance GenAI system (RevenueIQ) and an employment-ranking model (TalentMatch).
5. Define a prioritized remediation roadmap, decision gates, and executive reporting.

Scope and exclusions

In scope	Out of scope / separate workstream
Governance policy, risk appetite, committee and three-lines responsibilities	Legal conclusions or jurisdiction-by-jurisdiction compliance opinions
Use-case intake, inventory, tiering, impact assessment and lifecycle gates	ISO/IEC 42001 certification or formal readiness opinion
Control design, evidence requirements and sample test procedures	Production penetration testing, source-code review or vendor certification

In scope	Out of scope / separate workstream
Executed synthetic TalentMatch model and SQL validation exercise	Real applicant data, real employment decisions or a legally required independent bias audit
Illustrative RevenueIQ risk/control assessment and technical test plan	Operation of an actual contract-review model or reliance on its accounting conclusions

Planned advisory workplan

Phase	Weeks	Primary activities	Deliverables
Mobilize	1	Stakeholders, evidence request, scope, independence and legal interfaces	Charter; RACI; request list
Discover	1-2	Interviews, use-case discovery, policy and architecture review	Inventory; current-state map
Assess	3-5	Tiering, impact assessments, framework mapping, control design review	Tier decisions; gap matrix; RCM
Test	4-6	Data/model/control procedures for selected high-risk systems	Test workpapers; exceptions; evidence index
Report	7-8	Root cause, severity, management response and roadmap	Executive deck; detailed report; backlog

2. Governance operating model and lifecycle

Design principle: Business owners own AI outcomes and residual risk. Technology teams own system design and operation. Risk, compliance, privacy, security, legal, finance and HR set requirements and challenge. Internal Audit provides independent assurance; committees do not replace named accountability.

Decision rights and three lines

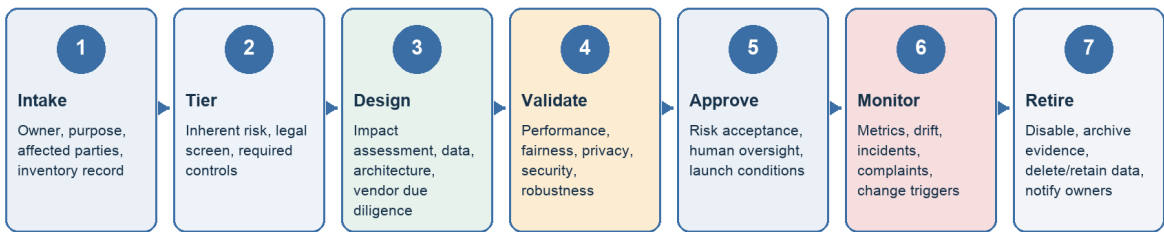
Role / line	Accountability	Decision evidence
Board / Audit Committee	Oversight of risk appetite, Critical-tier exposure and material incidents	Quarterly dashboard; exceptions; remediation aging
AI Risk Committee	Approve tiering standards, Critical-tier launches, risk acceptance and exceptions	Minutes; approval record; conditions; sunset date
1st line - business owner	Purpose, benefits, affected parties, controls, human oversight and monitoring	Use-case record; impact assessment; owner attestation
1st line - product / engineering	Data, model, architecture, testing, deployment, change and observability	System/model card; test pack; logs; release record
2nd line - risk functions	Policy, legal applicability, control requirements, challenge and escalation	Risk opinion; privacy/security review; issue log

Role / line	Accountability	Decision evidence
Finance / HR specialists	Domain validity for financial-reporting and employment decisions	Accounting/HR validation; reviewer qualifications
3rd line - Internal Audit	Independent assessment of governance and control effectiveness	Risk-based audit plan; workpapers; report

Lifecycle gates

Risk-Based AI Lifecycle Gates

Control intensity increases with risk tier; material change re-enters the lifecycle.



Examples of material change: new purpose, user population, geography, data source, model/vendor version, autonomy, threshold, or integration.

Figure 1. Risk-based lifecycle gates and material-change triggers.

Minimum control set by tier

Tier	Typical decision effect	Minimum governance treatment
Critical	Material legal, financial, rights, safety or autonomous operational impact	Committee approval; completed impact assessment; independent validation; enhanced human oversight; continuous monitoring; incident and rollback test
High	Significant customer, employee, security, privacy or operational impact	2nd-line approval; documented testing; human review; vendor/change controls; periodic monitoring
Moderate	Limited external or business effect with reversible decisions	Owner approval; standard assessment; baseline testing; periodic review
Low	Internal productivity, low sensitivity, no material decision reliance	Inventory; acceptable-use controls; approved tool/data; lightweight monitoring

3. Enterprise AI use-case inventory

The inventory is the system of record for scope, accountability, regulatory screening, control requirements and monitoring. A large enterprise may have hundreds or thousands of use cases; the ten below are a risk-calibrated sample selected for this portfolio.

ID	Use case	Owner	AI type	Decision / action	Tier
AI-001	RevenueIQ contract review copilot	Finance	GenAI + RAG	ASC 606 analysis draft; no autonomous posting	Critical
AI-002	TalentMatch applicant ranking	HR	Predictive ML	Prioritizes candidates for human review	Critical
AI-003	AgentOps cloud remediation	Engineering	Agentic AI	Executes bounded production recovery actions	Critical
AI-004	DisclosureDraft copilot	Finance / Legal	GenAI + RAG	Drafts SEC narrative and risk-factor text	Critical
AI-005	SupportGen customer assistant	Customer Ops	GenAI + RAG	Answers enterprise support questions	High
AI-006	CodePilot developer assistant	Engineering	GenAI	Suggests code and tests in controlled repositories	High
AI-007	SecOps Sentinel	Security	ML + GenAI	Prioritizes alerts and recommends containment	High
AI-008	DynamicPrice optimizer	Sales	Predictive ML	Recommends discounts within approval bands	High
AI-009	Marketing Studio	Marketing	GenAI	Drafts reviewed campaign content	Moderate
AI-010	MeetingMate notes	Corporate	Speech + GenAI	Summarizes approved internal meetings	Low

Required inventory metadata

- Owner, developer/provider, deployer, accountable approver and affected stakeholders.
- Intended purpose, decision role, autonomy, reasonably foreseeable misuse and prohibited use.
- Lifecycle stage, production status, users, geographies, legal entities and jurisdictions.
- Model/vendor/version, architecture, integrations, training/retrieval/input data and data sensitivity.
- Regulatory applicability, SOX relevance, risk tier, impact assessment, required controls and exceptions.
- Performance/fairness/security/privacy metrics, monitoring thresholds, incidents, complaints, changes and retirement date.

Tiering methodology

Step 1 - prohibited-practice screen: Escalate and block if the proposed practice is prohibited by law or enterprise policy; obtain counsel where applicability is uncertain.

Step 2 - impact: Rate 1-5 across people/fundamental rights, legal/regulatory, financial reporting, privacy/security, and safety/operational continuity. Use the highest credible dimension, not an average that masks severe harm.

Step 3 - likelihood: Rate 1-5 using exposure/scale, autonomy, data sensitivity, technical uncertainty, threat surface, and reversibility.

Step 4 - inherent score: Impact x likelihood. Critical 16-25; High 10-15; Moderate 5-9; Low 1-4.

Step 5 - overrides: At least Critical for autonomous material financial reporting, employment profiling/ranking in covered contexts, safety-critical action, or irreversible high-impact decisions. A regulatory high-risk classification overrides a lower numeric score.

Step 6 - residual risk: Re-rate only after control design and evidence are evaluated. Approval depends on residual risk, not control promises.

Example: RevenueIQ: impact 5 because an unsupported conclusion could affect material revenue recognition; likelihood 4 because GenAI retrieval and reasoning failures are plausible at enterprise scale. Inherent score 20 = Critical. Residual risk cannot be accepted until source traceability, validation, mandatory qualified review, change management, logging and monitoring are evidenced.

4. NIST AI RMF and ISO/IEC 42001 application

The frameworks serve different but complementary purposes. NIST AI RMF 1.0 organizes risk outcomes through GOVERN, MAP, MEASURE and MANAGE. ISO/IEC 42001 specifies an AI management system built around context, leadership, planning, support, operation, performance evaluation and improvement. This crosswalk is illustrative; exact ISO requirements must be checked against a licensed copy.

NIST AI RMF function	ApexCloud application	ISO/IEC 42001 high-level alignment	Evidence
GOVERN	Policy, risk appetite, inventory, roles, competence, third-party and issue governance	Clauses 4-7; policy, organization, resources and supplier-control themes	Policy; RACI; committee minutes; inventory; training; exceptions
MAP	Purpose, context, affected parties, data, harms/benefits, legal screen and impact assessment	Context/planning/operation; impact, data and interested-party themes	Use-case record; stakeholder map; impact assessment; data lineage
MEASURE	TEVV of performance, fairness, privacy, security, robustness and human oversight	Operation and performance evaluation; lifecycle and data controls	Test plan; datasets; code; results; model/system card; review
MANAGE	Risk treatment, approvals, monitoring, incidents, change, rollback and retirement	Planning, operation, evaluation and continual improvement	Risk acceptance; monitoring; incident record; corrective action; management review

Concrete application examples

Outcome	Control implementation	How I would test it
Inventory and accountability	Every AI use has an ID, owner, purpose, tier, lifecycle status and approval record.	Reconcile procurement/API/SaaS/expense/architecture sources to inventory; sample completeness and ownership.
Context and impact	Owner documents users, affected groups, autonomy, data, benefits, harms, misuse and legal screen.	Inspect impact assessment; challenge assumptions with product, legal, privacy, HR/finance and affected-stakeholder input.

Outcome	Control implementation	How I would test it
TEVV	Risk-tiered evaluation suite covers accuracy, grounding, fairness, privacy, security, robustness and human factors.	Reperform metrics on versioned data/code; evaluate thresholds, subgroup samples, exceptions and independent review.
Lifecycle change	Material changes require impact review, regression testing and reapproval before release.	Sample model/vendor/prompt/corpus/threshold releases; trace tickets to tests, approval, deployment and monitoring.
Ongoing monitoring	Metrics, incidents, complaints, overrides and drift trigger escalation or rollback.	Reperform dashboard measures; inspect alert disposition, incident timeliness and rollback exercises.

Current-version discipline

- NIST states that AI RMF 1.0 is under revision. The engagement should baseline the approved version, maintain a regulatory/standards change log, assess deltas and update controls deliberately.
- For GenAI, apply the NIST Generative AI Profile to risks such as confabulation, data privacy, information integrity, human-AI configuration, information security and third-party components.
- For impact assessments, ISO/IEC 42005:2025 provides complementary guidance on effects on individuals, groups and society across the lifecycle.

Source basis: NIST AI RMF official pages [S1-S3] and ISO official overviews [S4-S5].

5. Deep dive A - RevenueIQ finance GenAI

Use-case boundary: RevenueIQ extracts clauses and drafts an ASC 606 analysis with source citations. It is decision support only: a qualified human owns the accounting conclusion, material or unusual contracts require second-level review, and the system cannot post to the ERP or release external reporting.

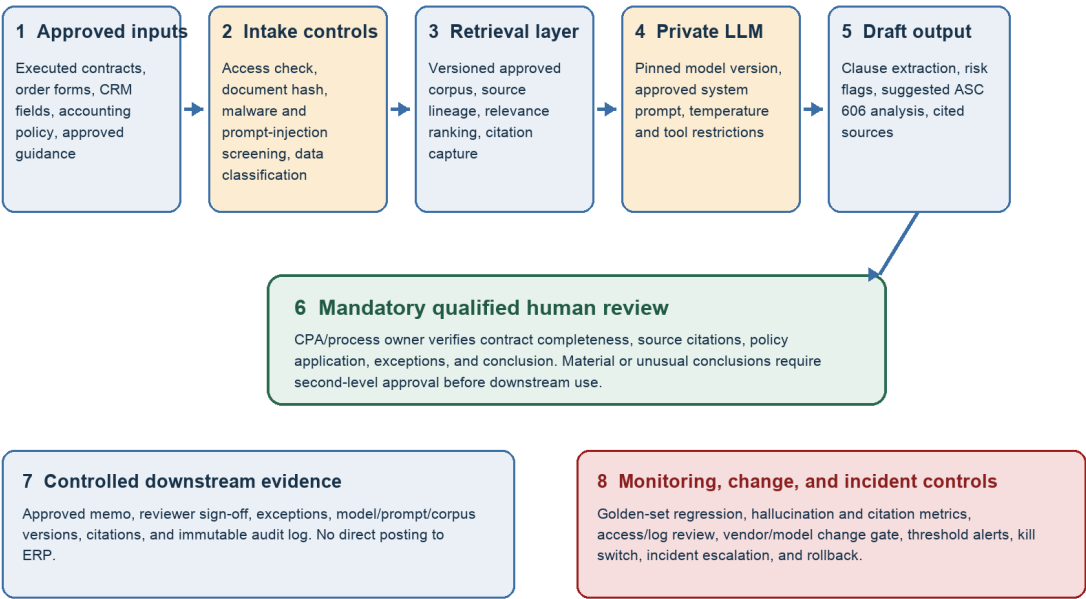
System context

Dimension	Illustrative assessment
Business objective	Reduce contract-review cycle time while improving clause identification and documentation consistency.
Inputs	Executed contracts/order forms; CRM data; approved accounting policy; authoritative guidance; prior approved examples.
Processing	Private-tenant retrieval-augmented generation using a versioned corpus and pinned model/prompt configuration.
Outputs	Clause extraction, risk flags, draft accounting memo and cited source passages.

Dimension	Illustrative assessment
Users / affected parties	Revenue accounting, controllership, auditors; customers/investors may be indirectly affected by reporting.
Decision role	Advisory; human CPA/process owner approves all conclusions and evidence.
Primary risk domains	Financial reporting, data quality, confabulation, access/privacy, prompt injection, change, third party, observability.
SOX relevance	Potentially relevant if management relies on the tool or its output in a key control or financial-reporting process.

RevenueIQ Contract Review Copilot - Controlled Architecture

Fictional finance GenAI use case | Human-approved decision support, not autonomous accounting



Evidence principle: every material output must be attributable to approved inputs, configuration, reviewer, decision, and retained support.

Figure 2. Controlled architecture and evidence boundary for RevenueIQ.

Completed impact-assessment example

Field	RevenueIQ assessment
Purpose / benefit	Faster and more consistent first-pass contract analysis; benefit measures are cycle time, reviewer effort and missed-clause rate.
Affected stakeholders	Finance staff, auditors, customers and investors; indirect impact if a material conclusion is wrong.
Foreseeable harms	Material misstatement, delayed close, confidentiality breach, unsupported memo, automation bias, inconsistent treatment, vendor outage.
Data	Confidential contracts and customer terms; source completeness, authorization, retention, residency and vendor use require control.
Human oversight	Named CPA/process owner reviews source completeness, citations and conclusion; second-level approval for material/unusual items.

Field	RevenueIQ assessment
Transparency / contestability	Output labels disclose AI assistance; reviewer can reject, correct and document overrides; issues feed the model/control backlog.
Monitoring	Factual/citation accuracy, retrieval recall, override rate, unresolved exceptions, model/corpus changes, access anomalies and incidents.
Residual decision	Critical - HOLD until validation, access, human-review, log, change and incident controls have passed readiness gates.

6. RevenueIQ AI risk-and-control matrix

The matrix connects inherent risk to a named control, accountable owner, retained evidence and a procedure that can support design or operating-effectiveness conclusions. The frequency is calibrated to the control objective and use-case tier.

Risk	Risk statement	Control design / owner	Required evidence	Sample test
R-01	Incomplete or stale retrieval misses a material clause.	C-01 Approved corpus manifest; source reconciliation per contract and corpus release. Owner: Revenue Controller.	Hashes, lineage, reconciliation, retrieval logs.	Select 25 outputs; trace all cited and expected clauses to executed source; inspect unresolved exceptions.
R-02	Confabulation or unsupported accounting reasoning.	C-02 Golden-set regression before release and monthly; block on critical threshold. Owner: Model Owner.	Versioned prompts, expected answers, scores, approval.	Reperform 100 cases; assess factual/citation accuracy, severity and approval of deviations.
R-03	Unauthorized contract or customer-data access.	C-03 RBAC, least privilege, DLP and quarterly access review. Owner: Data Owner/CISO.	Role matrix, approvals, access/DLP logs, review sign-off.	Sample joiners/movers/leavers; inspect privileged access and attempted restricted prompts.
R-04	Embedded instructions manipulate retrieval or output.	C-04 Document sanitization, content isolation and prompt-injection tests each release. Owner: Product Security.	Scanner logs, red-team cases, defect tickets.	Submit benign/malicious contract variants; confirm instructions are ignored, logged and escalated.
R-05	Model, prompt, corpus or vendor change bypasses validation.	C-05 Version pinning and material-change gate before production. Owner: Engineering Change Manager.	Change ticket, impact assessment, regression pack, approval.	Sample releases; trace configuration diff to tier review, testing, approval, deployment and rollback plan.
R-06	Reviewer over-relies on output or lacks competence.	C-06 Qualified review per contract; second approval for material/unusual conclusions. Owner: Revenue Controller.	Reviewer credentials, checklist, sign-offs, overrides.	Sample 30 contracts; inspect source verification, review depth, second approval and override rationale.
R-07	Draft output directly affects ledger or disclosure.	C-07 No direct ERP write; approved memo-to-ledger reconciliation. Owner: Financial Systems.	Integration config, access list, reconciliations, posting logs.	Inspect architecture and permissions; sample postings and trace to approved human conclusion.
R-08	Evidence cannot reconstruct the decision.	C-08 Immutable end-to-end log for every material output. Owner: Platform Owner.	Input hash, model/prompt/corpus version, citations, reviewer, timestamp.	Trace 25 decisions end-to-end; confirm retention, completeness, access and tamper evidence.
R-09	Quality degrades after launch.	C-09 Monthly observability dashboard with thresholds and escalation. Owner: Model Risk.	Accuracy, citation, override, drift and incident metrics.	Reperform measures; inspect alert completeness, timeliness, root cause, remediation and retest.
R-10	Third-party failure, reuse or silent version change.	C-10 Due diligence annually and on material change; contract controls and continuity test. Owner: Vendor Risk.	SOC/security/privacy reports, contract terms, SLA, exit/rollback test.	Inspect vendor evidence and gaps; verify model-change notice, data-use restrictions and exit readiness.

Control-design evaluation questions

- Does the control directly address the stated risk and operate early enough to prevent or detect harm?
- Is the owner independent and competent for the decision being reviewed?
- Is the frequency matched to use, change velocity and potential impact?
- Is the threshold explicit, approved and tied to a stop/escalate/rollback action?
- Could an independent reviewer reconstruct the population, procedure, exception, conclusion and approval from retained evidence?

7. RevenueIQ testing procedures and evidence requirements

Important distinction: The RevenueIQ procedures below are designed test steps and illustrative evidence requirements; no production RevenueIQ model was executed. The TalentMatch tests in Section 8 were actually run.

Test area	Procedure	Metric / criterion	Evidence retained
Source completeness	Create a stratified set of contracts by type, geography, value and complexity; reconcile expected clauses to retrieval.	100% source traceability for material conclusions; predefined retrieval-recall threshold.	Population, sampling rationale, expected clauses, source hashes, retrieval logs.
Factuality / grounding	Compare output claims and citations to executed contract and approved guidance; severity-rate unsupported statements.	No Critical unsupported conclusion; accuracy/citation thresholds approved before test.	Golden set, rubric, evaluator identity, code, result, exceptions, retest.
Accounting validity	Qualified reviewers evaluate conclusion, judgment, consistency and disclosure implications.	All material/unusual items receive second approval; unresolved differences block use.	Reviewer checklist, qualifications, conclusion and second sign-off.
Robustness	Vary formatting, clause order, wording, OCR quality and incomplete packages.	Performance remains within approved tolerance; graceful abstention on insufficient evidence.	Variant set, scores, failure modes and remediation.
Prompt injection / security	Embed adversarial instructions and restricted-data requests; inspect guardrail behavior.	No execution of document-borne instruction; attempts logged and escalated.	Attack cases, logs, screenshots/output, defect tickets and retest.
Access / privacy	Test role boundaries, sensitive prompts, retention and vendor-data-use settings.	Only authorized roles/data; no unapproved retention or model training.	Access matrix, configuration, DLP log, privacy/vendor review.
Human factors	Observe reviewers, test comprehension, automation bias, override and escalation.	Reviewer detects seeded errors; understands limitations; uses documented override.	Scenario script, participants, results, training and procedure changes.
Change / regression	Change model, prompt and corpus versions in a controlled environment; rerun critical tests.	No production release before approved regression and rollback readiness.	Version diff, change ticket, test pack, approval and deployment record.
Monitoring / incident	Reperform metrics and simulate threshold breach and kill switch.	Alert/triage/rollback within approved service levels.	Dashboard, alert, incident ticket, communications and post-incident review.

Evidence quality standard

- **Complete:** covers the full population or supports the sampling frame and exclusions.
- **Accurate:** reconciled to authoritative sources and independently reperformed where appropriate.
- **Versioned:** identifies data, model, prompt, corpus, code, threshold and environment.
- **Attributable:** identifies preparer, reviewer, approver, date, conclusion and open exceptions.
- **Tamper-evident and retained:** access-controlled, time-stamped and kept for the defined legal/audit period.
- **Decision-linked:** supports a GO, CONDITIONAL GO, HOLD, rollback, remediation or risk-acceptance decision.

Reusable impact-assessment template

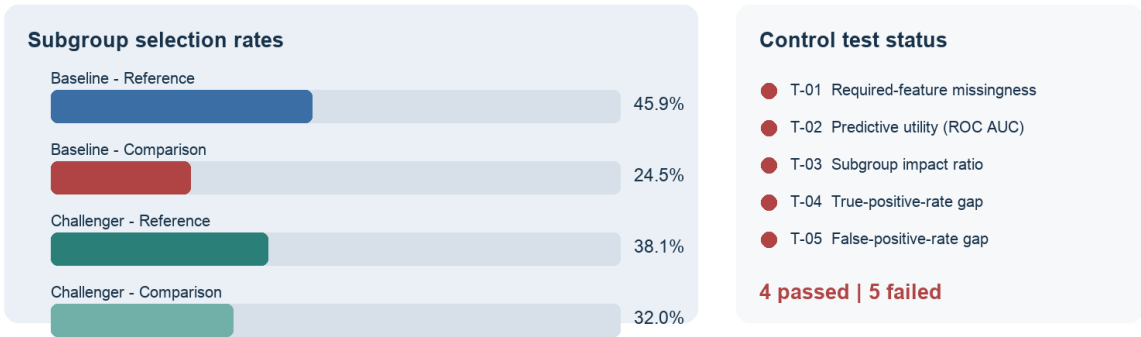
Section	Questions to answer before approval
Identity and ownership	What is the use-case ID, owner, provider/deployer, purpose, users, geography and lifecycle stage?
Decision and autonomy	What action or decision is influenced? Is it advisory, ranking, recommendation or autonomous? Can humans meaningfully intervene?
Stakeholders and impacts	Who benefits or may be harmed? What rights, safety, financial, privacy, security, access, environmental or societal effects are plausible?
Data and model	What training, retrieval and input data are used? What is the lineage, quality, sensitivity, representativeness and retention?
Legal / policy screen	What laws, sector rules, contracts, standards and internal policies may apply? Which questions require counsel?
Testing and thresholds	Which TEVV domains, subgroups, scenarios, acceptance criteria and independent reviewers are required?
Human oversight	Who reviews, with what competence, authority, time and information? How are overrides, appeals and accommodations handled?
Monitoring and change	Which metrics, incidents, complaints, drift and changes trigger review, rollback or retirement?
Residual decision	What residual risk remains, who accepts it, under what conditions, evidence, expiration and reapproval date?

8. Deep dive B - executed TalentMatch AI testing

I built and ran a seeded Python/SQL testing exercise for a fictional candidate-ranking model. The protected-group field was excluded from model inputs but used for subgroup testing. The baseline learned from intentionally biased historical decisions and included proxy-like referral, selective-school and career-gap variables. A constrained challenger used only structured, job-related inputs.

TalentMatch AI Testing - Executive Evidence

Synthetic portfolio exercise | Baseline vs. job-related challenger



Decision and evidence trail

- 1. Baseline deployment gate: HOLD - fairness, utility, and input-quality gates fail.
- 2. Root cause hypothesis: historical-label bias plus referral/school/career-gap proxies.
- 3. Challenger improves parity using structured, job-related variables; legal and HR validation still required.
- 4. Evidence retained: data lineage, feature definitions, coefficients, test results, thresholds, and limitations.

Not a real bias audit, employment decision, legal conclusion, or validation of a production system.

Figure 3. Executed synthetic test results; seed 42001; 6,000 records, including 1,800 held-out test records.

Executed results

Test	Result	Portfolio gate	Status	Interpretation
Required-feature missingness	18.3%	<= 5.0%	FAIL	Changed channel creates an incomplete referral feed; imputation affects behavior.
Baseline ROC AUC	0.623	>= 0.75	FAIL	Insufficient discrimination against synthetic job-success outcome.
Baseline impact ratio	0.534	0.80-1.25	FAIL	Comparison selection rate is materially lower; screening indicator, not legal conclusion.
Baseline TPR gap	0.244	<= 0.10	FAIL	Qualified candidates have materially different selection opportunity.
Baseline FPR gap	0.153	<= 0.10	FAIL	Error behavior differs across groups.
Score PSI	0.091	< 0.20	PASS	Score-distribution change stays within the exercise threshold.
AUC degradation	-0.008	<= 0.05	PASS	No performance decline in the simulated drift channel.
Challenger impact ratio	0.841	0.80-1.25	PASS	Parity improves when proxy-like inputs are removed.
Challenger TPR gap	0.089	<= 0.10	PASS	Residual gap passes the illustrative gate.

Decision and remediation

Disposition: HOLD the baseline. Investigate historical-label lineage and proxy variables; validate job relatedness and criterion validity; obtain HR, legal, privacy and accessibility review; test intersectional groups and uncertainty; define notices, accommodation, human review, overrides and appeals; independently validate a controlled challenger; monitor outcomes and complaints.

- Passing the 0.80 impact-ratio screen does not establish fairness or legal compliance; failing it is not by itself a legal conclusion.
- The challenger improves selected metrics but is not production-ready. Its synthetic 'job success' label and simplified groups are major limitations.
- The repository retains the dataset, dictionary, model coefficients, scored population, overall/subgroup metrics, SQL results, thresholds, code, evidence index and SHA-256 hashes.

SQL data-validation controls

Check	Purpose	Executed result
DQ-01	Duplicate applicant identifiers	PASS - zero exceptions
DQ-02	Missing required model inputs in source population	PASS - zero exceptions
DQ-03	Scores, years and binary fields within defined domains	PASS - zero exceptions
DQ-04	Valid subgroup and train/test labels	PASS - zero exceptions
DQ-05	Population reconciliation	PASS - 6,000 total; 4,200 train; 1,800 test
DQ-06	Subgroup representation and outcome reconciliation	PASS - four split/group records retained

Employment-AI context: EU AI Act official text [S6], EEOC selection-procedure guidance [S7], and NYC Local Law 144 guidance [S8].
Applicability and legal conclusions require counsel.

9. Executive findings and prioritized roadmap

The finding language below models assurance discipline: condition, criteria, cause, consequence, recommendation, owner, severity and validation plan. Except for the TalentMatch metrics, conditions are illustrative facts assumed for the fictional case.

ID	Severity	Condition	Risk / consequence	Owner	Target
F-01	Critical	No complete enterprise AI inventory or binding pre-use intake gate.	Shadow and embedded AI may bypass tiering, legal review, testing and monitoring.	CAIO / CIO	30 days
F-02	Critical	RevenuelQ lacks an approved golden set, release gate and source-traceability threshold.	A material accounting conclusion could be unsupported or unreconstructable.	CFO / Model Owner	60 days

ID	Severity	Condition	Risk / consequence	Owner	Target
F-03	Critical	TalentMatch baseline fails performance and subgroup gates in executed synthetic testing.	Poor utility and disparate outcomes make the baseline unfit for pilot.	CHRO / Model Risk	Hold now
F-04	High	Third-party model/version changes are not consistently linked to material-change assessment.	Silent change can invalidate prior testing and approvals.	Vendor Risk / Engineering	90 days
F-05	High	Observability logs do not consistently capture input, configuration, tool action, output, reviewer and decision.	Management cannot trace failures, evidence control operation or investigate incidents.	CTO / CISO	90 days
F-06	Moderate	Role-based AI literacy and human-review competence are not evidenced.	Reviewers may misunderstand limitations or apply inconsistent oversight.	HR / 2nd line	120 days

30 / 90 / 180 / 365-day roadmap

Horizon	Priority actions	Exit evidence
0-30 days	Appoint owners; issue interim policy; discover use cases; pause Critical launches; define incident/escalation path.	Inventory baseline; accountable owners; risk acceptance register; committee cadence.
31-90 days	Tier inventory; complete Critical impact assessments; implement RevenueIQ/TalentMatch gates; integrate vendor and change processes.	Approved tiers; test packs; RCMs; version/change evidence; hold/remediate decisions.
91-180 days	Operationalize GRC workflow, observability, role-based training, complaint/appeal and control self-assessment.	Workflow records; dashboards; training evidence; issue aging; management review.
181-365 days	Expand independent assurance, scenario exercises, metrics validation and ISO/IEC 42001 readiness decision.	Internal audit report; incident simulation; control effectiveness; continual-improvement plan.

Executive dashboard measures

- Inventory coverage, unowned use cases, tier distribution and overdue assessments.
- Critical/High use cases by lifecycle gate, validation status and unresolved launch condition.
- Performance, grounding, fairness, privacy, security, robustness and human-override threshold breaches.
- Material changes, vendor notices, exceptions, incidents, complaints, appeals, rollback and remediation aging.
- Evidence completeness and control effectiveness by accountable owner and business unit.

10. Concise executive findings presentation

The following six-slide storyline is intentionally decision-led. A Senior Associate should be able to present it in approximately eight minutes, then defend the methods and evidence in Q&A.

Slide	Headline	Decision-support content
Slide 1 - Decision	Four Critical use cases are not ready for unrestricted production; approve interim guardrails and a 90-day remediation program.	Ask: endorse hold criteria, owners and committee authority.
Slide 2 - Exposure	Ten sampled uses span finance, employment, infrastructure, customers and productivity; four are Critical, four High, one Moderate and one Low.	Show: inventory heat map and missing ownership/evidence.
Slide 3 - What failed	Inventory/intake, critical-use validation, change control, observability and competence evidence are incomplete.	Show: six findings by severity and root cause.
Slide 4 - Technical proof	TalentMatch baseline failed AUC, impact-ratio and error-gap gates; a constrained challenger improved parity but remains unapproved.	Show: selection rates, metrics, limitations and HOLD disposition.
Slide 5 - Target control system	Risk-tiered lifecycle gates connect policy, inventory, impact assessment, TEVV, approval, monitoring, incident, change and retirement.	Show: accountable three-lines operating model.
Slide 6 - Roadmap and value	Stabilize in 30 days, remediate Critical use cases in 90, scale evidence and observability in 180, and expand independent assurance in 365.	Ask: approve funding, owners, dates and residual-risk forum.

Likely executive questions

Question	Answer structure
Why not shut down all AI?	Differentiate inherent risk; preserve low-risk value; hold only uses whose residual risk and evidence are unacceptable.
What is the single biggest gap?	Incomplete inventory/intake: management cannot govern, test or monitor systems it cannot identify.
Can human review solve the risk?	Only if it is meaningful: competent reviewer, sufficient time/info/authority, clear escalation, tested ability to detect errors and evidenced decisions.
Why is the challenger not approved?	Metric improvement is necessary, not sufficient; validate purpose, label, job relatedness, subgroups, uncertainty, accessibility, legal obligations and operations.
How do we know controls work?	Define objective, population, owner, frequency, evidence, threshold, exception, conclusion and independent re-performance.

Engagement vocabulary bank

Term	How to use it precisely
Use-case inventory	System of record for purpose, owner, model, data, tier, status, approvals, controls, monitoring and change.
Intended purpose	Specific use, users, context and decision role for which the system is designed and approved.
Reasonably foreseeable misuse	Plausible off-label or abusive use that governance should anticipate and control.
Inherent / residual risk	Risk before controls / remaining risk after design and operating effectiveness are evidenced.

Term	How to use it precisely
TEVV	Test, evaluation, verification and validation across technical and sociotechnical outcomes.
Grounding / confabulation	Use of authoritative context / confident output unsupported by reliable source evidence.
RAG	Retrieval-augmented generation: retrieving context for a generative model; retrieval and generation each require testing.
Human oversight	A meaningful, competent and evidenced ability to understand, challenge, override, escalate or stop the system.
Observability	Logs, traces, outputs, data flows and metrics that support detection, investigation, control evidence and improvement.
Material change	Purpose, data, model/vendor, prompt, corpus, autonomy, threshold, population, geography or integration change that can invalidate prior approval.
Contestability	Mechanism for an affected person or reviewer to question, correct, appeal or seek human reconsideration.
Model / system card	Versioned description of purpose, data, design, metrics, limitations, prohibited uses and monitoring.

11. Limitations, extensions and primary sources

What I would add with real client access

- Evidence-based maturity assessment from interviews, policies, architecture, tickets, logs, testing repositories, vendor documents and control operation.
- Jurisdiction and legal-entity applicability matrix developed with counsel, including current implementation dates and regulatory changes.
- Representative stakeholder input, accessibility/accommodation testing, intersectional fairness analysis and statistical uncertainty.
- Production technical testing using approved environments, real model/version information, secured data and independent review.
- Management responses, agreed owners/dates, remediation validation and reporting under applicable professional standards.

Primary sources

[S1] NIST, AI Risk Management Framework: <https://www.nist.gov/itl/ai-risk-management-framework>

[S2] NIST, AI RMF 1.0 (NIST AI 100-1): <https://doi.org/10.6028/NIST.AI.100-1>

[S3] NIST, Generative AI Profile (NIST AI 600-1): <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>

[S4] ISO, ISO/IEC 42001 AI management systems overview: <https://www.iso.org/standard/42001>

[S5] ISO, ISO/IEC 42005 AI system impact assessment overview: <https://www.iso.org/standard/42005>

[S6] European Union, Regulation (EU) 2024/1689 (AI Act): <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng>

[S7] U.S. EEOC, Employment Tests and Selection Procedures: <https://www.eeoc.gov/laws/guidance/employment-tests-and-selection-procedures>

[S8] NYC DCWP, Automated Employment Decision Tools: <https://www.nyc.gov/site/dca/about/automated-employment-decision-tools.page>

[S9] PwC, Responsible AI and audits: <https://www.pwc.com/us/en/tech-effect/ai-analytics/responsible-ai-audits.html>

[S10] PwC, AI risk modeling: <https://www.pwc.com/us/en/services/audit-assurance/risk-modeling-services/ai-risk-modeling-services.html>

[S11] PwC, Assurance for AI: <https://www.pwc.com/us/en/services/audit-assurance/digital-assurance-transparency/assurance-ai.html>

[S12] PwC, AI observability: <https://www.pwc.com/us/en/tech-effect/ai-analytics/ai-observability.html>

Portfolio repository contents

- Case-study DOCX/PDF and separate interview playbook.
- TalentMatch Python source, SQL validation, synthetic data, data dictionary, model parameters and scored outputs.
- Overall/subgroup metrics, test criteria and status, evidence index, run summary, visual and integrity hashes.
- Explicit README, test plan and model card with limitations and non-reliance language.

Closing position: My differentiator is not pretending that an audit background automatically equals AI-model expertise. It is applying disciplined scoping, risk assessment, control design, evidence evaluation, professional skepticism and executive communication - while building the technical depth to test AI outcomes credibly.